ONE-PAGE BRIEF

Post-quantum cryptography review: obp-api @ 6a4a13ef079f

Client: TESOBE (Open Bank Project) — public repository (passive review) · Source: github.com/OpenBankProject/OBP-API, commit `6a4a13ef079f` · Reviewed: 2026-11-06 10:11 UTC · Risk profile: Crypto exchange, custodian or wallet

POST-QUANTUM MATURITY

Level 0 of 4

no post-quantum cryptography

FINDINGS

0 Critical **24** High **12** Medium **5** Low **3** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)

Key establishment: 10 + 5 − 8 = 7 → **too late**

Signatures: 10 + 5 − 8 = 7 → **too late**

Next step: Inventory where classical public-key cryptography protects long-lived data and keys, and choose the first migration: usually a hybrid TLS key exchange and wrapped keys.

WHAT MATTERS MOST

High QSI-2026-17438	**Certificate has expired (app.example.com)** What to do: Renew the certificate and automate renewal (e.g. ACME) with expiry monitoring.
High QSI-2026-17443	**Certificate has expired (app.example.com)** What to do: Renew the certificate and automate renewal (e.g. ACME) with expiry monitoring.
High QSI-2026-17463	**org.postgresql:postgresql 42.7.11 is affected by GHSA-j92g-9f8w-j867 (CVE-2026-54291)** What to do: Upgrade to a fixed version (42.7.12).
High QSI-2026-17464	**org.xerial.snappy:snappy-java 1.1.10.4 is affected by GHSA-gwq9-9ffj-mvrv (CVE-2026-93451)** What to do: Upgrade to a fixed version (1.1.10.9).

37 more in the full report.

WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

Role	Algorithms	What to do
Medium key wrapping and data encryption at rest	RSA	Wrap keys with ML-KEM or a hybrid KEM (X25519 + ML-KEM-768) and re-wrap the stored keys; data that may…
Medium authentication and identity (certificates, tokens, device attestation)	RSA	Keep credentials short-lived and plan ML-DSA certificates, tokens and keys as the ecosystem supports them
Medium role not determined	RSA	Classify each usage, record data lifetimes, and plan migration to ML-DSA (FIPS 204) or SLH-DSA (FIPS 205)…

KNOWN VULNERABLE COMPONENTS

Advisories for the versions in use: 18; each needs checking against the code.

Static review of source code and manifests; files analysed: 1190. No requests were sent to the owner's systems.

Full report, content SHA-256: `6e83fddb11fe4c5dcc78ace863f481960b11f629a8378ee1992ce77d9bae882f`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.